

32 — Security Operations Specification

Version 1.0

Product-Level Engineering Specification

Core operating rule: Security operations can detect, investigate, contain, and recommend; they do not bypass governance or directly create trusted state.

Document	Value
System	CloudShield AI
Specification	32 — Security Operations
Version	1.0
Scope	Product-wide security operations, including DAIL security operations
Primary Cloud	AWS for MVP
Status	Engineering Baseline
Depends On	00–31

Document Map

- 1. Purpose and Scope
- 2. Security Operations Objectives
- 3. Security Operations Operating Model
- 4. Security Monitoring Architecture
- 5. Security Event Taxonomy and Severity
- 6. Roles and Responsibilities
- 7. Incident Lifecycle
- 8. Detection Engineering
- 9. Security Alert Pipeline
- 10. SIEM / SOAR Integration
- 11. CloudShield-Native Detections
- 12. AWS, IAM, and Cloud Detections
- 13. API and Web Security Detections
- 14. AI / LLM Security Detections
- 15. DAIL Security Detections
- 16. External Integration and Webhook Detections
- 17. Terraform and Infrastructure Drift Detections
- 18. Threat Intelligence and Enrichment
- 19. Investigation Workflows
- 20. Containment and Isolation
- 21. Credential and Cloud Account Compromise Response
- 22. AI Prompt Injection / Model Abuse Response
- 23. Promotion and Policy Safety Incidents
- 24. Evidence Preservation and Forensics
- 25. Security Audit and Compliance Operations
- 26. Vulnerability Management

- 27. Security Configuration Baselines
- 28. Security Testing and Red Teaming
- 29. Security Metrics, KPIs, and KRIs
- 30. Security Dashboards
- 31. Alert Fatigue and Triage
- 32. Escalation and Runbooks
- 33. Incident Communications
- 34. Post-Incident Review
- 35. Security Automation Boundaries
- 36. Environment-Specific Operations
- 37. Retention and Access Control
- 38. MVP Security Operations Baseline
- 39. Implementation Sequence
- 40. Security and Functional Acceptance Criteria
- 41. Traceability
- 42. Engineering Decisions
- 43. Definition of Done
- 44. Glossary

1. Purpose and Scope

This specification defines how CloudShield AI operates as a security-aware product after deployment. It establishes the people, processes, telemetry, detections, workflows, controls, and response mechanisms required to identify security-relevant activity, investigate it, contain or isolate affected scope, preserve evidence, and recover safely.

The specification applies to the CloudShield AI product as a whole and includes DAIL as a bounded security-sensitive subsystem. It complements, rather than replaces, the product security/threat model, observability architecture, lifecycle controls, cloud integration contracts, and AI safety specifications.

Security operations is an operational control plane. It is not an alternative authorization path.

1.1 In Scope

- Security monitoring and detection across application, cloud, infrastructure, AI, DAIL, integrations, and data planes.
- Alert triage, investigation, incident handling, containment, recovery, and post-incident review.
- Detection engineering, rule lifecycle, severity, correlation, enrichment, suppression, and tuning.
- SIEM/SOAR integration and security automation boundaries.
- Security evidence preservation and forensic readiness.
- Security audit/compliance operations, vulnerability management, security baselines, testing, metrics, dashboards, escalation, and runbooks.

1.2 Out of Scope

- Replacing Specification 08's product-wide threat model.
- Granting security operators unrestricted production mutation privileges.
- Allowing detections or automation to bypass authorization, DAIL verification, policy, approval, promotion, or trusted-state controls.
- Operating as a general-purpose enterprise SOC beyond explicitly authorized product integrations.
- Training a proprietary foundation model as part of security operations.

2. Security Operations Objectives

Objective	Operational Requirement	Success Condition
Detect	Identify security-relevant activity with useful fidelity.	High-value events become actionable alerts or durable security events.
Understand	Provide enough context for rapid investigation.	Actor, scope, resource, action, time, and evidence can be reconstructed.
Contain	Limit blast radius without unsafe secondary changes.	Affected scope is isolated using governed controls.
Preserve	Retain trustworthy evidence.	Evidence is integrity-protected and linked to the incident.
Recover	Return to a known safe state.	Recovery is re-observed and reconciled.
Learn	Improve detections and controls.	Post-incident actions become tracked engineering work.
Govern	Keep operations subordinate to governance.	No security workflow creates trusted state by itself.

2.1 Security Operations Principles

- Least privilege.
- Evidence first and provenance by default.
- Fail closed on critical safety conditions.
- Separate observation from authority.
- Deterministic enforcement for policy/lifecycle gates.
- Human accountability for high-impact actions.
- Tenant and scope isolation.
- Safe degradation when AI, SIEM, enrichment, or external integrations fail.

3. Security Operations Operating Model

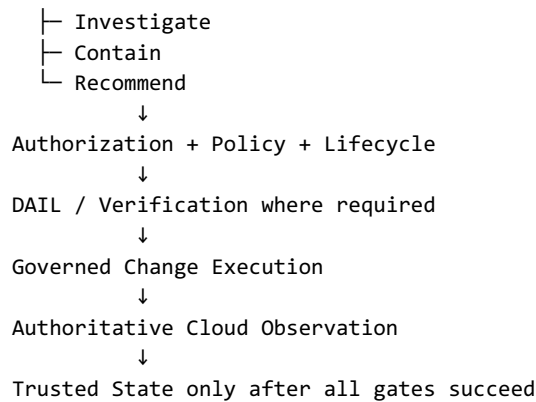
Telemetry → Normalization → Detection/Correlation → Alert → Triage
→ Investigation → Containment/Remediation → Recovery/Reconciliation
→ Evidence/Audit → Post-Incident Learning → Control Improvement

3.1 Operating Planes

Plane	Purpose	Examples
Telemetry	Collect and normalize security signals.	Logs, traces, cloud events, identity events, audit events.
Detection	Evaluate signals against detection logic.	Rules, thresholds, correlations, behavioral detections.
Case	Track alerts/incidents/tasks through lifecycle.	Alerts, cases, incidents, escalations.
Response	Contain and recover through governed actions.	Token revocation, integration quarantine, approved isolation.
Evidence	Preserve facts and artifacts.	Raw events, snapshots, hashes, timelines.
Governance	Enforce authorization and policy.	RBAC, policy, DAIL verification, approval, promotion.

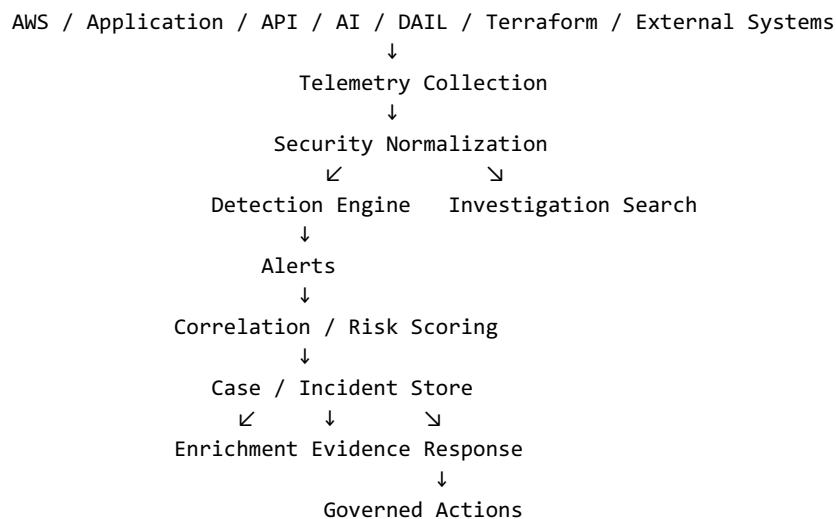
3.2 Operational Control Boundary

Security Operations
└─ Detect



4. Security Monitoring Architecture

Security operations consumes Specification 31's telemetry architecture and adds security-specific normalization, detection, correlation, case management, enrichment, and response layers.



4.1 Security Telemetry Sources

- CloudShield application logs, audit events, authentication/authorization events, and lifecycle events.
- AWS CloudTrail and relevant AWS service telemetry for CloudShield and authorized customer scopes.
- IAM identity and role activity.
- API gateway, load balancer, WAF, and network telemetry where deployed.
- LLM gateway request, safety, and tool-use telemetry.
- DAIL verification, dependency, impact, and promotion telemetry.
- Terraform plan/apply/drift and infrastructure CI/CD telemetry.
- Inbound/outbound integration and webhook telemetry.
- Security scanning and vulnerability findings.

4.2 Security Event Normalization

Field	Requirement
event_id	Globally unique identifier.
event_time	Authoritative event time plus source timestamp when available.
tenant_id	Mandatory tenant scope for tenant-owned data.
actor	Human, service, role, integration, or automation identity.

action	Normalized action category.
resource	Canonical asset/resource identity when resolvable.
source	Telemetry origin/provider.
severity	Normalized security severity.
outcome	Success, failure, blocked, denied, unknown, or partial.
correlation_id	Request/job/trace/case correlation where available.
provenance	Source and confidence metadata.
raw_reference	Pointer to original evidence where permitted.

5. Security Event Taxonomy and Severity

5.1 Event Categories

- **IDENTITY** — authentication, authorization, privilege, session, credential, and role activity.
- **CLOUD** — cloud API activity, resource changes, network/security changes, key management, and account activity.
- **APPLICATION** — application errors, abuse, suspicious commands, policy violations, and sensitive operations.
- **API** — anomalous requests, token abuse, rate anomalies, and authorization failures.
- **AI** — prompt injection, unsafe tool requests, policy violations, data exfiltration, model abuse, and safety-gate failures.
- **DAIL** — verification anomalies, dependency manipulation, promotion safety failures, candidate changes, and evidence-integrity issues.
- **INTEGRATION** — webhook abuse, OAuth misuse, replay, and external trust failures.
- **INFRASTRUCTURE** — Terraform drift, artifact/image changes, network changes, and deployment deviations.
- **DATA** — unauthorized access, export, deletion, integrity, or retention anomalies.
- **SECURITY_CONTROL** — disabled controls, detection gaps, policy changes, or monitoring blind spots.

5.2 Severity Model

Severity	Meaning	Examples	Expected Response
SEV-1 Critical	Active/probable compromise or material control-plane/trusted-state impact.	Cloud account compromise; cross-tenant exposure; trusted-state integrity threat.	Immediate escalation and containment.
SEV-2 High	Significant risk needing rapid investigation or containment.	Privileged credential misuse; major AI tool-abuse attempt.	Rapid triage and normally same-window containment.
SEV-3 Medium	Credible concern with limited/uncertain impact.	Suspicious API behavior; moderate drift.	Investigate/remediate by SLA.
SEV-4 Low	Low-risk anomaly or control signal.	Isolated failed-login pattern.	Review/tune/aggregate.
SEV-5 Informational	Routine security signal.	Successful control action.	Retain for analytics/audit.

Severity considers impact, confidence, affected scope, privilege, exploitability, data sensitivity, trusted-state relevance, and containment difficulty. AI severity suggestions are advisory and require deterministic validation.

6. Roles and Responsibilities

Role	Primary Responsibilities	Restricted Actions
Security Operator	Triage, investigate, preserve evidence, execute approved containment.	Cannot bypass lifecycle/policy or self-approve sensitive changes.
Security Lead	Own severity, escalation, response coordination, and security	Cannot override immutable

	decisions.	audit/evidence controls.
Platform/Cloud Engineer	Investigate infrastructure/cloud behavior and implement engineering fixes.	Cannot convert investigation directly into trusted state.
AI Security Engineer	Investigate model abuse, prompt injection, tool safety, AI controls.	Cannot authorize unsafe tool execution.
DAIL Engineer	Investigate verification, dependency, evidence, promotion anomalies.	Cannot bypass DAIL gates.
Incident Commander	Coordinate major incidents, communications, priorities, recovery.	Cannot grant technical privileges merely by incident status.
Auditor/Compliance	Review evidence, controls, access, compliance posture.	Read-only by default.
Automation Identity	Perform narrowly scoped pre-authorized response.	Must be least-privileged, auditable, policy-bound, revocable.

7. Incident Lifecycle

DETECTED → TRIAGED → CONFIRMED / DISMISSED → INVESTIGATING
→ CONTAINING → CONTAINED → ERADICATING / REMEDIATING
→ RECOVERING → VERIFYING → RESOLVED → POST_INCIDENT_REVIEW → CLOSED

- Every incident retains originating alerts, evidence, actors, affected assets, decisions, actions, and timestamps.
- Dismissal requires a recorded reason and evidence basis.
- Critical incidents cannot close merely because an alert stops firing; authoritative state must be re-observed.
- Recovery does not imply trusted state until normal lifecycle requirements succeed.
- Ambiguous external mutation outcomes remain in reconciliation.

7.1 Incident Classification

- Security Incident — confirmed/probable compromise, policy breach, or material security-control failure.
- Security Event — relevant signal not yet confirmed as an incident.
- Control Incident — security mechanism is degraded, bypassed, disabled, or untrustworthy.
- Data Incident — confidentiality, integrity, availability, or retention concern involving protected data.

8. Detection Engineering

IDEA → DESIGN → TEST → REVIEW → DEPLOY → MONITOR → TUNE → RETIRE

- Every production detection has a unique ID, owner, purpose, severity model, data dependencies, test cases, and version.
- Document expected true-positive and known false-positive conditions.
- Critical detections require regression tests against attack and benign datasets.
- Detection changes are versioned and auditable.
- Retired detections remain historically discoverable.

8.1 Detection Rule Contract

Field	Requirement
detection_id	Stable unique identifier.
version	Immutable rule version.
signal_scope	Events/data sources consumed.
logic	Deterministic expression or documented model-based logic.
severity	Default severity and escalation conditions.

confidence	Confidence calculation/classification.
owner	Accountable owner.
tests	Positive, negative, boundary, regression tests.
response	Allowed response playbooks.
suppression	Explicit bounded suppression conditions.
expiry	Review/expiry date for temporary exceptions.

9. Security Alert Pipeline

Raw Event → Normalize → Deduplicate → Enrich → Detect → Correlate
→ Score → Create/Update Alert → Route → Triage → Case/Incident

- Deduplicate using stable identifiers where available.
- Alerts preserve originating event references.
- Correlation can combine identity, cloud, application, AI, DAIL, and integration signals.
- Routing considers tenant, severity, affected scope, business impact, and ownership.
- Failed enrichment must not silently downgrade high-risk events.

10. SIEM / SOAR Integration

CloudShield AI exposes provider-neutral security integration boundaries. MVP can use native security capabilities while supporting enterprise SIEM/SOAR adapters.

Integration	Inbound	Outbound	Safety Boundary
SIEM	Security events, normalized alerts, audit/security telemetry.	Detections, incidents, evidence references.	Cannot change trusted state.
SOAR	Enrichment/approved response results.	Explicit response requests/playbook events.	Must remain authenticated and policy-bound.
Ticketing	Ticket updates/status.	Incident/case/task creation.	Ticket status is not lifecycle state.
Notification	Delivery status.	Security notifications/escalations.	Minimum necessary data only.

11. CloudShield-Native Detections

- Repeated authorization failures followed by successful privileged access.
- Unexpected lifecycle transitions or direct state mutation attempts.
- Verification results changing without matching candidate/version changes.
- Promotion attempts with stale/invalidated impact analysis.
- Trusted-state changes without expected evidence/audit sequence.
- Audit/evidence write failures for security-critical actions.
- Unexpected tenant/scope access attempts.
- AI outputs attempting prohibited actions or safety-gate bypass.
- Unusual bulk remediation candidate generation.
- Security-control configuration changes without authorized policy/version change.

12. AWS, IAM, and Cloud Detections

- Unexpected role assumption from unusual principals, locations, workloads, or time windows.

- Privilege escalation indicators and policy changes affecting sensitive roles.
- Creation/modification/deletion of access keys outside approved workflows.
- CloudTrail or security telemetry disablement/deletion/degradation.
- Security-group, network ACL, route, load-balancer, or public-exposure changes outside expected windows.
- Unexpected KMS, secrets, storage, database, or identity-policy changes.
- Cross-account access inconsistent with registered CloudShield connections.
- High-volume cloud API activity inconsistent with known automation.
- Resource creation/deletion outside authorized workflows.
- Account-level security configuration changes weakening visibility.

13. API and Web Security Detections

- Authentication brute-force and credential-stuffing patterns.
- Token reuse, suspicious token age, issuer/audience mismatch, or session anomalies.
- Cross-tenant object access attempts.
- Repeated authorization failures against sensitive resources.
- Abnormal request volume, burst patterns, or endpoint enumeration.
- Malformed/adversarial inputs indicating injection attempts.
- Unexpected administrative API use or privilege changes.
- Bulk export or unusual evidence/security-data access.
- Webhook signature failures and replay attempts.

14. AI / LLM Security Detections

- Direct prompt injection requesting policy bypass, credential disclosure, hidden instructions, or unrestricted tools.
- Indirect prompt injection in resource descriptions, source files, tickets, documents, or external integration content.
- AI requests containing secrets or unnecessary sensitive customer data.
- Unsupported high-impact claims or missing required structured output fields.
- Repeated safety-gate failures or prohibited tool-call generation.
- Tool-call requests exceeding capability, scope, or target.
- Unusual token usage, request volume, or cost spikes.
- Model/provider behavior changes correlated with elevated safety failures.
- Attempts to make AI output appear verified, approved, promoted, or trusted without lifecycle evidence.

The LLM can recommend. It cannot verify, approve, promote, or create trusted state.

15. DAIL Security Detections

- Candidate version changes after verification starts.
- Verification references stale, missing, or mismatched candidate versions.
- Dependency graph changes that materially alter blast radius during verification/approval.
- Evidence artifacts missing, altered, or inconsistent with verification results.
- Verification bypass, partial verification treated as complete, or gate-order violations.
- Promotion attempts without required DAIL verification or with invalidated results.
- Repeated verification failures suggesting unsafe candidate generation or environmental drift.
- Unauthorized access to DAIL verification/promotion interfaces.
- Unexpected automation identity use against DAIL resources.

DAIL Security Event → Block/Quarantine when required → Preserve Evidence
→ Open Case → Reconcile Candidate + Dependency + Verification State

16. External Integration and Webhook Detections

- Invalid/missing webhook signatures.
- Webhook replay, timestamp drift, duplicate delivery, or sequence anomalies.
- OAuth token use from unexpected clients/scopes.
- Integration capability use outside registered permissions.
- Unexpected external attempts to mutate sensitive CloudShield resources.
- Abnormal outbound delivery volume or unusual destinations.
- External content causing repeated AI safety violations.
- Connector configuration changes without authorized lifecycle changes.

17. Terraform and Infrastructure Drift Detections

- Production infrastructure differs from approved Terraform/CloudShield-controlled state.
- Manual resource changes outside approved workflow.
- Unexpected IAM, networking, logging, encryption, or exposure changes.
- Terraform state integrity/backend access anomalies.
- Plan/apply results materially differ from candidate intent.
- Drift disables or weakens security controls.
- Infrastructure changes without corresponding audit, candidate, or deployment evidence.

Infrastructure drift is a security signal and may trigger containment, but drift alone does not authorize rollback.

18. Threat Intelligence and Enrichment

- Enrichment may add IP/domain/identity/resource context, reputation, vulnerability context, and organizational metadata.
- External intelligence is untrusted input and cannot directly authorize mutation.
- Every enrichment result has source, timestamp, confidence, and freshness/expiry.
- Enrichment failure must not suppress native high-severity detections.
- Customer-specific context may refine generic intelligence subject to policy.

19. Investigation Workflows

1. Confirm alert authenticity and correlate duplicates.
2. Identify actor, identity, source, tenant, cloud scope, resource, and time window.
3. Reconstruct the sequence using logs, traces, audit events, cloud evidence, and domain state.
4. Determine whether affected state is observed, proposed, verified, or trusted.
5. Assess direct and transitive impact using the canonical dependency model.
6. Determine safe containment options.
7. Preserve evidence before destructive actions where practical.
8. Execute only authorized containment/remediation.
9. Re-observe authoritative state and reconcile ambiguous outcomes.
10. Record conclusion, residual risk, and engineering follow-up.

19.1 Investigation Record

Component	Required Content
Timeline	Ordered event/action sequence with source timestamps.
Scope	Tenant, account, region, assets, identities, integrations.
Actor	Human/service/integration identity and authorization context.

Evidence	Raw or integrity-protected references supporting findings.
Hypothesis	What may have happened and confidence.
Impact	Security, availability, confidentiality, integrity, trusted-state impact.
Actions	Containment, remediation, recovery, and performer.
Decision	Disposition, severity, residual risk, approval basis.
Follow-up	Detection/control/product changes and owners.

20. Containment and Isolation

- Containment actions are explicit, least-privileged, reversible where practical, and auditable.
- Examples: disable compromised session, revoke token, quarantine integration, restrict workload, block high-risk operation.
- Customer-cloud containment uses registered cloud connection and authorized execution role.
- Emergency access is not a general-purpose bypass for DAIL/governance/promotion.
- Emergency containment may block further actions without changing trusted state.

Containment protects the system; promotion remains a separate governed lifecycle.

21. Credential and Cloud Account Compromise Response

Suspected Compromise

- Confirm / Bound Scope
- Preserve Evidence
- Revoke / Disable Credential
- Invalidate Sessions/Tokens
- Assess Recent Activity
- Identify Affected Resources
- Re-observe Cloud State
- Rotate/Reissue Credentials
- Verify Security Baseline
- Close or Escalate

- Credential rotation must not destroy evidence.
- Suspected cloud-account compromise is treated as potentially SEV-1 until bounded.
- Correlate recent privileged activity with the affected identity.
- Post-containment verification confirms revoked access is no longer effective.

22. AI Prompt Injection / Model Abuse Response

11. Quarantine the affected request, context source, tool request, or integration where feasible.
12. Preserve prompt/context provenance and safety telemetry subject to policy.
13. Determine whether the model only generated text or attempted/triggered a tool operation.
14. If a tool operation occurred, investigate the resulting action independently.
15. Invalidate affected AI-derived candidate state when safety assumptions are no longer trustworthy.
16. Re-run deterministic validation and DAIL verification before consequential progression.
17. Add the pattern to adversarial evaluation and detection regression suites.

23. Promotion and Policy Safety Incidents

- Promotion without required verification is a security-control incident.

- Stale approval, invalidated impact analysis, or mismatched candidate version blocks promotion.
- Failed post-change verification requires reconciliation and may invalidate trusted state.
- Unexpected trusted-state changes trigger high-priority investigation.
- Security operations may suspend further promotion through governed controls but cannot manufacture trusted state.

Safety Incident → Stop/Block Sensitive Actions → Preserve Candidate/Verification/Evidence
 → Investigate Lifecycle Integrity → Reconcile Authoritative State
 → Repair Controls/Candidate → Re-verify → Governed Promotion if safe

24. Evidence Preservation and Forensics

- Security-critical evidence is timestamped, attributable, integrity-protected, and incident-linked.
- Raw evidence is preserved separately from analyst interpretations.
- Evidence references retain provenance and source identity.
- Use hashes and immutable/object-lock-capable storage where appropriate.
- Sensitive evidence access is least-privileged and audited.
- Retention follows tenant, contractual, security, and compliance policy.

Evidence Type	Examples	Minimum Handling
Identity	Auth, role assumptions, token/session events.	Immutable reference + access audit.
Cloud	CloudTrail, configuration snapshots, resource state.	Provenance + timestamp + integrity protection.
Application	API logs, traces, audit events.	Correlation IDs + redaction + retention.
AI	Request metadata, safety events, structured output, tool calls.	Data minimization + provenance.
DAIL	Candidate, verification, impact, evidence, promotion records.	Version binding + integrity protection.
Infrastructure	Terraform plans/applies/drift artifacts.	Versioned artifact + source commit/plan reference.

25. Security Audit and Compliance Operations

- Maintain auditable records for authentication, authorization, privileged access, policy changes, incidents, and consequential actions.
- Support evidence collection for access reviews, control tests, incident reviews, and compliance posture.
- Distinguish configuration intent, observed state, verification result, and trusted state.
- Audit exports preserve tenant boundaries and evidence provenance.
- Audit users are read-only by default.

26. Vulnerability Management

- Track vulnerabilities across dependencies, containers/images, infrastructure, cloud configurations, and integrations.
- Record affected asset/component, severity, exploitability, evidence, owner, status, target, and exception where applicable.
- Accelerate vulnerabilities affecting internet exposure, privileged components, sensitive data, or security controls.
- AI remediation remains a candidate until validation, impact analysis, DAIL verification where applicable, and governance.
- Closed vulnerabilities require re-scan or equivalent verification.

27. Security Configuration Baselines

Baseline Area	Examples
Identity	MFA, least privilege, role trust, credential rotation, session controls.
Cloud	Logging, encryption, public exposure, security groups, storage access, key controls.
Application	Secure headers, authorization, secret handling, dependency hygiene.
API	Authentication, authorization, rate limits, input validation, webhook verification.
AI	Prompt/context boundaries, output validation, tool allowlists, quotas.
DAIL	Verification gating, candidate immutability, evidence integrity, promotion separation.
Infrastructure	Terraform control, artifact provenance, network segmentation, secrets, backups.
Observability	Security logging, audit durability, alerting health, retention.

Baselines are versioned policy artifacts. A deviation becomes a finding, accepted exception, or remediation candidate; it is never silently treated as compliant.

28. Security Testing and Red Teaming

- Unit/integration tests for security controls and detections.
- Adversarial tests for authentication, authorization, tenant isolation, cloud integrations, AI, DAIL, and promotion.
- Direct and indirect prompt-injection testing using realistic external-content sources.
- Replay, race, stale-state, ambiguous-outcome, and evidence-integrity testing.
- Controlled AWS integration environments for cloud-response tests.
- Red-team findings become tracked security work with owner, severity, evidence, and closure verification.

28.1 Security Test Families

- Preventive controls.
- Detective controls.
- Containment/response.
- Recovery/reconciliation.
- Adversarial AI.
- Tenant isolation.
- Privilege boundaries.
- Evidence/audit integrity.
- Failure-injection and chaos tests for security-critical dependencies.

29. Security Metrics, KPIs, and KRIs

Metric	Purpose
MTTD	Detection speed.
Mean Time to Triage	Initial analyst responsiveness.
MTTC	Containment speed.
MTTR	Safe recovery speed.
Critical Detection Coverage	Coverage of prioritized threat scenarios.
Detection Precision	Alert usefulness / false-positive burden.
Critical Alert Miss Rate	Detection blind spots from tested scenarios.
Security Event Durability	Required-event retention rate.

Evidence Completeness	Required evidence availability for critical incidents.
Privilege Boundary Violations	Attempted/actual authorization bypasses.
DAIL Safety-Gate Failures	Verification/promotion safety failures.
Trusted-State Integrity Incidents	Unexpected trusted-state changes.
Drift Exposure	Unresolved security-relevant infrastructure drift.
Credential Compromise Exposure	Affected scope and containment time.
AI Safety Violation Rate	Unsafe/blocked model interactions.

30. Security Dashboards

- Security Operations Overview — incidents, critical alerts, detection health, affected scopes.
- Identity & Privilege — suspicious authentication, privileged actions, role/credential events.
- Cloud Security — AWS activity, public exposure, logging health, configuration drift.
- AI Security — injection detections, safety blocks, tool-call denials, model anomalies, abuse/cost signals.
- DAIL Security — verification failures, stale-state blocks, promotion anomalies, evidence integrity.
- Infrastructure Security — Terraform drift, deployment anomalies, artifacts/images, baseline deviations.
- Incident Command — timeline, owners, severity, containment, evidence, communications.
- Detection Health — coverage, false positives, lag, failed sources, tuning backlog.

Dashboards are operational views, not authoritative state stores.

31. Alert Fatigue and Triage

- Prioritize by severity, confidence, privilege, scope, asset criticality, and trusted-state relevance.
- Use bounded deduplication/suppression; critical events must not be indefinitely suppressed.
- Group correlated alerts while preserving individual evidence.
- Temporary suppressions require owner, reason, scope, and expiry.
- Tuning must not reduce critical attack-path coverage merely to improve volume.
- Unknown/stale/incomplete telemetry is surfaced as a monitoring gap, not as a clean result.

32. Escalation and Runbooks

32.1 Escalation Triggers

- SEV-1 or suspected cloud-account compromise.
- Trusted-state integrity anomaly.
- Cross-tenant isolation failure or credible attempt.
- Evidence/audit integrity failure affecting a critical incident.
- Repeated DAIL verification/promotion bypass attempts.
- AI tool execution causing or potentially causing consequential unauthorized changes.
- Security telemetry blind spot affecting critical controls.

32.2 Required Runbooks

- Compromised credential.
- Compromised cloud account/role.
- Tenant-isolation suspicion.
- Prompt injection / AI tool abuse.

- DAIL verification/promotion integrity incident.
- Terraform/security-baseline drift.
- Webhook/OAuth integration compromise.
- Evidence/audit integrity failure.
- Security telemetry outage.
- Critical vulnerability response.

33. Incident Communications

- Communications are role-based and minimum-necessary.
- SEV-1 incidents require a designated incident commander and security lead.
- External/customer communication follows approved organizational and contractual procedures.
- Status updates distinguish confirmed facts, hypotheses, containment status, and uncertainty.
- Sensitive credentials, tokens, exploit details, and unnecessary customer data are excluded from broad channels.
- Closure communication requires verified recovery and documented residual risk.

34. Post-Incident Review

18. Reconstruct timeline and control-path behavior.
19. Identify root cause and detection/response gaps.
20. Assess lifecycle, authorization, DAIL, and trusted-state control failures.
21. Assess evidence completeness and auditability.
22. Create corrective actions with owners and due dates.
23. Add relevant attack patterns to detection/security-test suites.
24. Review automation boundaries.
25. Verify corrective actions before review closure.

35. Security Automation Boundaries

Automation	Allowed	Not Allowed
Alert enrichment	Yes, within bounded permissions.	Changing authoritative state.
Deduplication	Yes.	Suppressing critical events without policy.
Containment	Yes, if explicitly pre-approved as a bounded playbook.	Unrestricted production mutation.
Credential revocation	Yes, when pre-authorized and least-privileged.	Bypassing audit/policy.
AI investigation	Yes, advisory.	Treating model output as source evidence without validation.
AI remediation	Candidate creation only.	Direct promotion/trusted-state creation.
DAIL verification	Defined automated verification steps.	Skipping required gates.
Promotion	Normal governed promotion workflow only.	Security-operator direct override.

36. Environment-Specific Operations

Environment	Security Operations Policy
Development	Verbose telemetry; synthetic/secrets-safe data; aggressive testing; no production credentials.
Test	Security regression, attack simulation, integration tests; controlled cloud test accounts.

Staging	Production-like controls; representative detection and incident drills; no accidental customer impact.
Production	Strict least privilege, governance, evidence durability, escalation, fail-closed behavior.

Emergency production response may stop unsafe activity but does not grant permanent bypass authority.

37. Retention and Access Control

- Security telemetry, alerts, cases, evidence, and audit records have explicit retention classes.
- Retention is configurable by environment, tenant policy, contractual requirements, and data classification.
- Sensitive evidence access is logged and periodically reviewed.
- Deletion respects legal/compliance holds where applicable.
- Security operations cannot silently delete evidence to reduce storage or alert volume.
- Tenant-scoped access is enforced at application and data layers.

38. MVP Security Operations Baseline

- Centralized structured logs, security audit events, metrics, traces, and correlation IDs.
- Native security event normalization and alerting.
- AWS CloudTrail/IAM/cloud-change visibility for CloudShield and authorized customer scopes.
- Core authentication, authorization, tenant-isolation, and privileged-activity detections.
- Lifecycle, DAIL, verification, promotion, and trusted-state integrity detections.
- AI safety and prompt-injection detection baseline.
- Terraform drift and security-baseline monitoring.
- Case/incident lifecycle with evidence references.
- Critical containment runbooks and least-privileged automation.
- Security dashboards and critical alerting.
- Evidence retention and audit access controls.
- Security regression and adversarial test baseline.
- SIEM/SOAR integration interfaces.

39. Implementation Sequence

26. Implement security event schema and normalization.
27. Implement security case/incident lifecycle.
28. Implement core native detections and alert routing.
29. Integrate AWS security telemetry and IAM/cloud detections.
30. Implement privileged-access and tenant-isolation detections.
31. Implement AI safety/security detections and tool-boundary telemetry.
32. Implement DAIL integrity/promotion-safety detections.
33. Implement Terraform drift/security-baseline detections.
34. Implement evidence preservation and investigation tooling.
35. Implement bounded containment playbooks.
36. Implement security dashboards and metrics.
37. Integrate SIEM/SOAR/ticketing interfaces.
38. Run adversarial/security regression suites.
39. Conduct incident-response drills and tune runbooks.
40. Establish post-incident learning and detection governance.

40. Security and Functional Acceptance Criteria

ID	Acceptance Criterion
SECOPS-AC-001	Every security-critical event has durable provenance and correlation metadata.
SECOPS-AC-002	SEV-1/SEV-2 alerts route to an accountable operational owner.
SECOPS-AC-003	Critical incidents retain a reconstructable timeline from authoritative evidence.
SECOPS-AC-004	Security automation cannot bypass authentication, authorization, policy, DAIL verification, or promotion controls.
SECOPS-AC-005	Credential-compromise containment uses least-privileged, auditable paths.
SECOPS-AC-006	AI prompt injection is detected/blocked and cannot directly create trusted state.
SECOPS-AC-007	DAIL verification/promotion integrity anomalies generate alerts and block unsafe progression.
SECOPS-AC-008	Tenant-isolation violations are detectable and actionable.
SECOPS-AC-009	Terraform/security-baseline drift becomes explicit security state.
SECOPS-AC-010	Evidence integrity failures are themselves security events.
SECOPS-AC-011	Critical detections have automated positive/negative regression coverage.
SECOPS-AC-012	Security telemetry outages create monitoring-health signals.
SECOPS-AC-013	Incident closure requires verified recovery or documented residual risk.
SECOPS-AC-014	Consequential security operations are attributable to a human or automation identity.
SECOPS-AC-015	Security operators cannot directly manufacture VERIFIED, APPROVED, PROMOTED, or TRUSTED state.

41. Traceability

Upstream Specification	Security Operations Dependency
00 — Master System	Product boundary, trust model, end-to-end control loop.
01 — SRS	Security, reliability, observability, governance, and functional requirements.
02 — Architecture	Service boundaries, trust boundaries, deployment and data flows.
03 — Functional	Lifecycle behavior, use cases, failure and response behavior.
04 — Product & UX	Operator workflows, incident UX, dashboards, safe-path design.
05 — Domain & Data	Security event, asset, candidate, evidence, audit, and policy semantics.
06 — State & Lifecycle	Observed/proposed/verified/trusted states and transitions.
07 — Identity & Dependency	Canonical identity, graph, blast radius, invalidation.
08 — Security & Threat Model	Threat taxonomy, controls, trust boundaries.
09 — Intelligence & AI Architecture	AI abstraction, context, routing, tool boundaries.
10 — LLM Integration	Provider integration, request/response, safety telemetry.
11 — AI Safety	Prompt injection, output/tool guardrails, fail-safe AI.
12–26 — DAIL Package	DAIL verification, evidence, experiments, testing, development, promotion controls.
27 — AWS & Terraform	AWS infrastructure, IAM, Terraform, drift, observability.
28 — API	Authentication, authorization, lifecycle-safe API operations.
29 — Cloud Integration	AWS discovery, identity, mutation, reconciliation.
30 — External Integration	Webhooks, OAuth, ITSM, CI/CD, notifications, external trust boundaries.
31 — Observability & Logging	Logs, metrics, traces, events, audit, evidence, telemetry reliability.

42. Engineering Decisions

- Security operations is product-wide and includes DAIL as a security-sensitive subsystem.
- Native security operations are provider-neutral; SIEM/SOAR are adapters, not authorities.
- Security detections may block or contain explicitly authorized actions but cannot create trusted state.
- AI is advisory; deterministic controls remain authoritative.
- Evidence is separated from operational logs and analyst conclusions.
- Unknown/stale/incomplete telemetry is explicit uncertainty or monitoring gap.
- Emergency response is bounded, auditable, revocable, and not a permanent privilege path.
- MVP favors reliable high-value workflows and strong evidence over a large catalog of shallow detections.
- Detection logic, baselines, runbooks, and response playbooks are versioned engineering artifacts.

43. Definition of Done

- Security event schemas and normalization are implemented and versioned.
- Alert/incident lifecycle is durably auditable.
- Core AWS, IAM, API, tenant, AI, DAIL, integration, and infrastructure detections are implemented for MVP.
- Critical detections have automated regression tests.
- Critical response runbooks are documented and tested in controlled environments.
- Least-privileged containment automation is implemented where approved.
- Evidence preservation and integrity controls are operational.
- Security dashboards expose incidents, detection health, control failures, and KRIs.
- Telemetry degradation creates explicit operational alerts.
- SIEM/SOAR integration boundaries are documented/tested.
- Security operators cannot bypass governance or create trusted state.
- Incident drills demonstrate detection → investigation → containment → recovery → verification → closure.
- Post-incident review produces trackable corrective actions.
- Traceability to Specifications 00–31 is maintained.

44. Glossary

Term	Definition
Security Event	Security-relevant observed signal that may or may not represent an incident.
Alert	Detection-generated actionable signal requiring triage/correlation.
Incident	Confirmed or sufficiently probable security event requiring coordinated response.
Detection	Versioned logic used to identify security-relevant behavior.
Containment	Action intended to limit further impact while preserving safe control.
Evidence	Integrity-protected information supporting investigation or decision.
Audit Event	Record of who/what performed or authorized a consequential action.
SIEM	Security information and event management system.
SOAR	Security orchestration, automation, and response system.
KPI	Key performance indicator measuring operational performance.
KRI	Key risk indicator measuring security risk exposure.
DAIL	CloudShield AI subsystem responsible for dependency-aware lifecycle, impact, verification, and related controls.
Trusted State	State earned only after required verification, governance, promotion, and authoritative confirmation.
Drift	Difference between expected/controlled state and authoritative observed state.

Fail Closed	Block sensitive progression when required safety conditions cannot be established.
Reconciliation	Process of resolving ambiguous/incomplete external outcomes using authoritative observation.

Final architectural rule: Security operations can detect, investigate, contain, and recommend. It cannot bypass governance, DAIL verification, or promotion controls, and it cannot directly create trusted state.